

ROOTS-AI™ Secure Kickoff & Access Provisioning Checklist v1.0.1 - CONTROLLED CORRECTION

Document ID: ROOTS-MVP-KICKOFF-001 | Controlled correction to v1.0

This correction sheet is integral to the attached v1.0 release and supersedes only the clauses identified below. All other ownership, least-privilege, environment-separation, secret-handling, billing, backup, monitoring and access-removal controls remain in force.

1. Package reference - Section 6

Supersedes: "All eight package files."

Controlled wording: "Complete current ROOTS-AI Controlled Reference Package - all files listed in the current issue/reference register are accessible and checksum-verified." No fixed package-file count is an acceptance criterion.

2. Data terminology - Sections 3, 4 and 6

Supersedes "No secrets/PHI", "Scrub PHI/PII before transmission", and "PHI/PII flow" where used as universal legal classifications.

Controlled wording: use "secrets / PII / personal data / health-related data" as the baseline terminology. "PHI" applies only where the applicable legal or contractual context classifies the data as PHI. This clarification does not reduce any security, minimization, scrubbing, access-control or audit requirement.

3. Operational acceptance boundary - Section 6 heading

Supersedes heading: "G0/G1 Acceptance Record."

Controlled heading: "Pre-Day-0 / G0-G1 Operational Acceptance Record."

Mandatory boundary: Completion of this checklist does **not** constitute M1 acceptance or authorize M1 payment. M1 acceptance remains governed by the signed Agreement v7.3 and requires the applicable G0-G2 evidence and written ROOTS-AI acceptance, including the repository/environments, architecture, secure database/migrations, authentication, RLS foundation, assessment shell, autosave/resume, and current traceability/test evidence demonstrated on Staging as required by the controlling agreement/baseline.

4. Precedence

If the attached v1.0 pages conflict with this correction on the three matters above, this v1.0.1 correction controls. No other scope, milestone, ownership, security or technical requirement is changed by this correction.

ROOTS-AI™ Phase 1 MVP

Secure Kickoff, Account Ownership & Access Provisioning Checklist — Version 1.0

Document ID: ROOTS-MVP-KICKOFF-001

Status: APPROVED OPERATIONAL CHECKLIST

Effective date: upon contract execution

This file completes the operational handoff without exposing passwords, API keys or tokens. Secrets must be exchanged only through an approved password manager or provider invitation. No secret value belongs in email, chat, source code, tickets or this document.

1. Day-0 Ownership Rule

ROOTS AI HEALTH SYSTEMS, Inc. owns or controls the repository, domain/DNS, hosting, database, authentication, storage, email, AI provider, monitoring and billing accounts wherever the provider permits. The implementation partner receives named, least-privilege, time-limited access. Shared root credentials are prohibited.

2. Required Accounts and Provisioning Evidence

Service	Required owner	Partner access	Evidence at G0/G1
GitHub organization/repository	ROOTS owner	Partner developer role	Owner screenshot; branch rules; recovery contacts
Vercel team/project	ROOTS owner/billing	Project developer	Owner/billing screenshot; environment list
Supabase organization/projects	ROOTS owner/billing	Environment-specific developer	Development, Staging, Production project IDs; RLS owner
OpenAI API project	ROOTS owner/billing	Restricted project key via secret manager	Project ID; budget cap; retention/data-control setting record
Transactional email provider	ROOTS owner	Restricted sender/config access	Verified sending domain; template IDs; logs restricted
Domain and DNS	ROOTS owner	DNS editor only if required	Registrar/DNS owner and recovery control
Monitoring/error tracking	ROOTS owner	Developer role	Data-scrubbing configuration; alert routes
Password manager/secrets vault	ROOTS owner	Named vault access	Membership and removal test
Analytics consent platform	ROOTS owner	Public-site config only	Protected-route exclusion evidence
Backup/recovery storage	ROOTS owner	Operational role only	Retention and restore evidence

3. Environment Separation

Control	Development	Staging	Production
Data	Synthetic only	Synthetic/UAT unless expressly approved	Approved participant data
Credentials	Distinct	Distinct	Distinct; strongest access controls
Deployment	Feature branches	Approved develop/release flow	Protected release/tag only
Admin users	Named	Named + MFA	Named + MFA; minimum number
Logging	No secrets/PHI	Scrubbed	Scrubbed; audited
AI inputs	Synthetic	Minimized test objects	Minimized approved objects only

4. Non-secret Configuration Register

Variable category	Examples	Rule
Application	APP_ENV, APP_URL, REPORT_VERSION	Record names and purpose; values per environment.
Supabase	SUPABASE_URL, project ID	Public identifiers may be documented; service keys remain in vault.

Variable category	Examples	Rule
Authentication	Magic Link expiry, redirect allow-list	Values approved and tested.
OpenAI	Project/model identifier, prompt version	No API key in documentation.
Email	Sender name, sender domain, template IDs	No SMTP/API secret.
Storage	Private bucket names, signed URL expiry	No public report bucket.
Monitoring	Project identifiers, alert owners	Scrub PHI/PII before transmission.
Analytics	Public route allow-list, consent mode	Explicit deny-list for assessment/report/auth/admin.

5. Secure Provisioning Sequence

1. ROOTS creates the organization/account and enables MFA and recovery contacts.
2. ROOTS invites named partner personnel with the minimum role.
3. The partner confirms access without receiving ROOTS owner passwords.
4. Secrets are created inside the target provider or approved vault and mapped to the correct environment.
5. A second authorized ROOTS administrator verifies ownership, billing and recovery.
6. The Architecture Gate records account IDs, processors, regions and recurring costs.
7. Access is reviewed weekly and removed at handover or earlier when no longer required.

6. G0/G1 Acceptance Record

Item	Required evidence	Acceptance
Contract and issue register	Executed contract; hashes match issue register	Pass/Fail
All eight package files	Files accessible and checksum-verified	Pass/Fail
Repository	ROOTS owner; protected main; develop branch	Pass/Fail
Account inventory	Provider, region, owner, billing, role, purpose	Pass/Fail
Processor register	Service, data fields, purpose, region, agreement status	Pass/Fail
Architecture package	Diagram, ERD, API list, RLS map, PHI/PII flow	Pass/Fail
Recurring cost register	Plan, expected monthly cost, billing owner	Pass/Fail
Secret handling	Vault/provisioning flow demonstrated; no secret in documents	Pass/Fail
Access removal test	One test account revoked and verified	Pass/Fail

7. Named Contacts to Record in the Executed Contract or Kickoff Minutes

- ROOTS business owner and authorized approver.
- ROOTS technical/account owner.
- Implementation partner project lead and security lead.
- Designated contractual notice emails.
- Security-incident 24-hour notification channel.
- Privacy request owner and escalation path.

These contact values are partner- and account-specific operational data, not missing product requirements. They are recorded at contract execution or G0 and do not change the fixed technical scope.